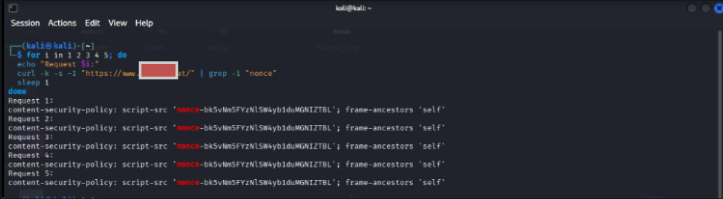


Go back



[P4] Static CSP Nonce Across All Requests — XSS Protection Defeated on [REDACTED]

Submitted 27 days ago • Last activity 26 days ago

ID	ac3c067f-653f-4003-8df1-b77e85e4f9c6
Submitted	26 Feb 2026 23:04:43 GMT+0
Target Location	* [REDACTED]
Target category	Web App
VRT	Server Security Misconfiguration > Potentially Unsafe HTTP Method Enabled
Priority	P5
Bug URL	https://[REDACTED]/
Description	Vulnerability: Static Content Security Policy (CSP) Nonce Summary: The Content Security Policy header on www.akhwiem.at uses a static nonce value that never changes between requests. A CSP nonce must be cryptographically random and unique per request. A static nonce completely defeats the purpose of the CSP, allowing any XSS payload to execute by simply referencing the known static nonce value. Static Nonce Observed: nonce-bk5vNm5FYzNISW4yb1duMGNIzTBL This identical value was returned across every single request tested, across multiple sessions and days. Steps to Reproduce: 1. Send any request to https://www.[REDACTED] <pre>curl -k -s -I "https://www.[REDACTED]/" grep -i "nonce"</pre> Result: <pre>content-security-policy: script-src 'nonce-bk5vNm5FYzNISW4yb1duMGNIzTBL'; frame-ancestors 'self'</pre> 1. Repeat the request 5 times: <pre>for i in 1 2 3 4 5; do curl -k -s -I "https://www.[REDACTED].at/" grep -i "nonce" sleep 1 done</pre> Result: Identical nonce returned every single time: <pre>nonce-bk5vNm5FYzNISW4yb1duMGNIzTBL nonce-bk5vNm5FYzNISW4yb1duMGNIzTBL nonce-bk5vNm5FYzNISW4yb1duMGNIzTBL nonce-bk5vNm5FYzNISW4yb1duMGNIzTBL nonce-bk5vNm5FYzNISW4yb1duMGNIzTBL nonce-bk5vNm5FYzNISW4yb1duMGNIzTBL</pre> Screenshot:  Impact: A CSP nonce is designed to allowlist specific inline scripts on a per-request basis. When the nonce is static and predictable, an attacker who finds an XSS injection point anywhere on the domain can bypass the CSP entirely by including the known nonce in their injected script tag: <pre><script nonce="bk5vNm5FYzNISW4yb1duMGNIzTBL"> malicious_payload() </script></pre> This renders the entire CSP script-src policy ineffective, meaning any XSS vulnerability on www.[REDACTED] has no CSP barrier preventing script execution. As an attacker I could: Use this static nonce to bypass CSP protections and execute arbitrary JavaScript in a victim's browser if any XSS vector exists on the domain, potentially stealing session cookies, credentials, or patient-facing data on a government hospital platform. Additional Observation: The same static nonce is also present across backend bypass IPs [REDACTED], confirming this is a server-wide misconfiguration rather than isolated to a single endpoint. References:

Status

Informational

This submission was reproducible but is considered informational. It may be that the issue is a best practice recommendation, low risk, has existing mitigations in place, or is an accepted business risk for the customer.

Reward

VRT version

1.17

Engagement

Submitted to



Bounty

Closed on

28 Feb 2026

CrowdStream visibility

Choose to show your details with this submission in CrowdStream when accepted.

Please note: your username will always be shown with your submission if it is disclosed.

Show username

Show reward

Disclosure policy

Please note: This engagement does **not allow** disclosure. You may not release information about vulnerabilities found in this engagement to the public.

Need help?

Issues with a submission? Please visit [Bugcrowd Support](#) and create a support ticket.

- OWASP CSP Cheat Sheet
- https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html
- W3C CSP Specification — Nonce requirements

Files attached

 image-2026-02-26T23:03:06.042Z.png (102 KB)

Activity



rahat_rab created the submission
27 days ago (26 Feb 2026 23:04:43 GMT+0)



rahat_rab sent a message
27 days ago (26 Feb 2026 23:11:12 GMT+0)

Note to triager: The VRT category was incorrectly selected during submission. This finding relates to a misconfigured Content Security Policy (static nonce), not HTTP methods. Please reclassify under Server Security Misconfiguration > Misconfigured Content Security Policy if possible. Thank you.



bugcrowd changed the severity to **P5**
26 days ago (28 Feb 2026 06:10:08 GMT+0)



bugcrowd changed the state to **Informational**
26 days ago (28 Feb 2026 06:10:09 GMT+0)



bugcrowd sent a message
26 days ago (28 Feb 2026 06:10:13 GMT+0)

Hi rahat_rab,

Thank you for your submission, however, this issue is considered to be a P5 (Informational) finding as per [Bugcrowd's Vulnerability Rating Taxonomy \(VRT\)](#). Therefore, this finding typically does not qualify for a reward.

Typically, this is the case when an issue lacks a demonstrated risk and is considered security best practice. While that will apply regularly when we assign a submission a P5 rating, if you are able to exploit this finding further (or chain it with other findings) to meet the definition of another item within the VRT, please do submit a new report. We look forward to reading it!

As you progress with bug bounties it's important to consider not just the vulnerability but also the impact that this vulnerability has, so we encourage you to always explore any finding to better understand the impact it may have. Each submission should aim to answer the question "as an attacker I could...".

If you're unsure of the next steps to take this with submission, we recommend the [Bugcrowd University](#) as a starting point for learning how you can escalate bugs from a P5, into P4s or even P3 findings!

Best regards,
 bugcrowd

Request a response

You can request a response from the customer or Bugcrowd about your submission. [Learn more.](#)

Submit a request 2 of 2 available



Send a message

To  Everyone

B *I*     

Write **Preview**

Your message to everyone here...

Embed images by dragging & dropping, **selecting**, or pasting them.

 **Add attachments**

You can attach up to 20 files. Please keep individual upload size under 400MiB.

You can embed attachments (.jpg/.gif/.png, smaller than 5MB) into the Markdown fields. You can copy the embed code using the 'Copy as Markdown' button.

Send message